

# Thndr

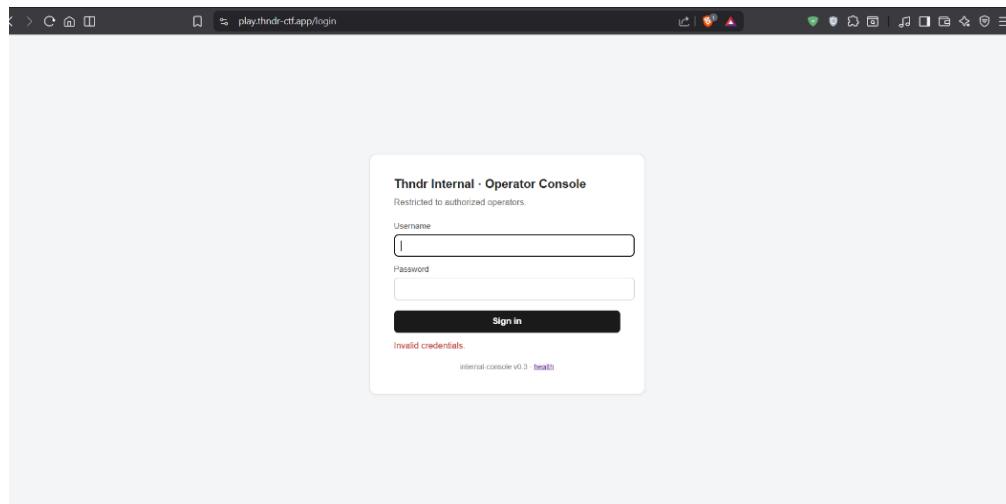
## CTF Report

Created by: Ziad Ahmed

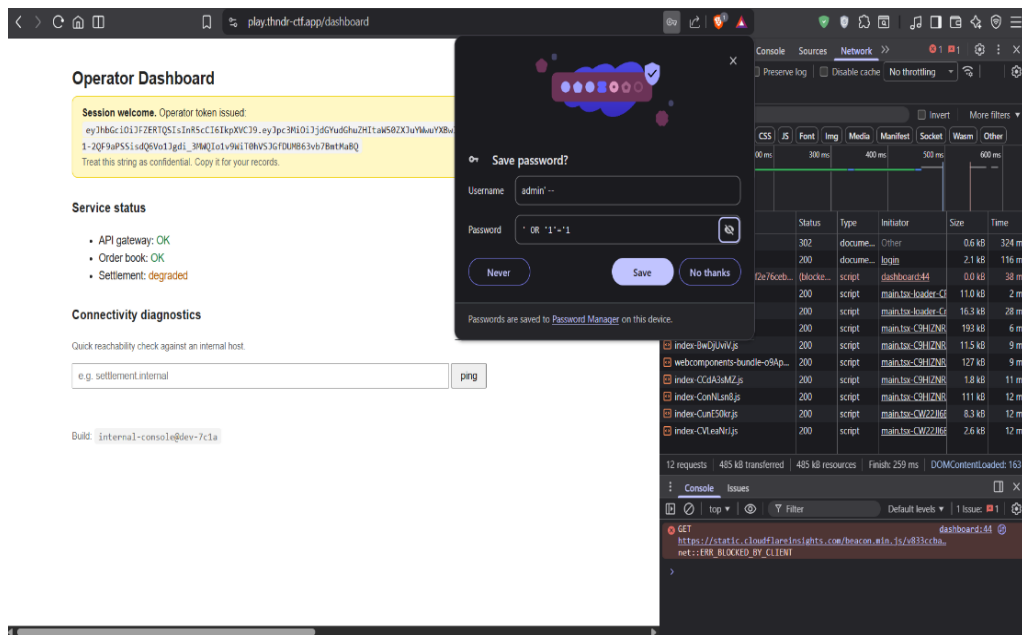
## Flag 1: SQL Injection

### Vulnerability

While testing the login form, I noticed inconsistent login errors.



I attempted a basic SQL injection payload which successfully bypassed authentication.



### How to Fix?

Fixing the code by putting input validation and least-privilege DB permissions.

## First flag:

f1=eyJhbGciOiJFZERTQSIlnR5cCl6IkpXVCJ9.eyJpc3MiOiJkdGYudGhuZHItaW50ZXJuYWwuYXBwIiwic3ViOiJoiemlpYWRkYWhtbWVkbZEBnbWFpbC5jb20iLCJmbGFnljoizjEiLCJpYXQiOiJl3Nzk2MzA4ODEsImV4cCl6MTc3OTc2MDQ4MSwianRpljoieYTk1NjMyMzUtNmI0Zi00NmRiLWFiYmYtMGI5NDNiMDZiNTU5In0.MubzzbpbzmarUGw1GVnJH0ep2cW-1-2QF9aPSSisdQ6Vo1Jgdi\_3MWQIo1v9WiT0hVSJGfDUMB63vb7BmtMaBQ

## Flag 2: Command Injection

## Vulnerability

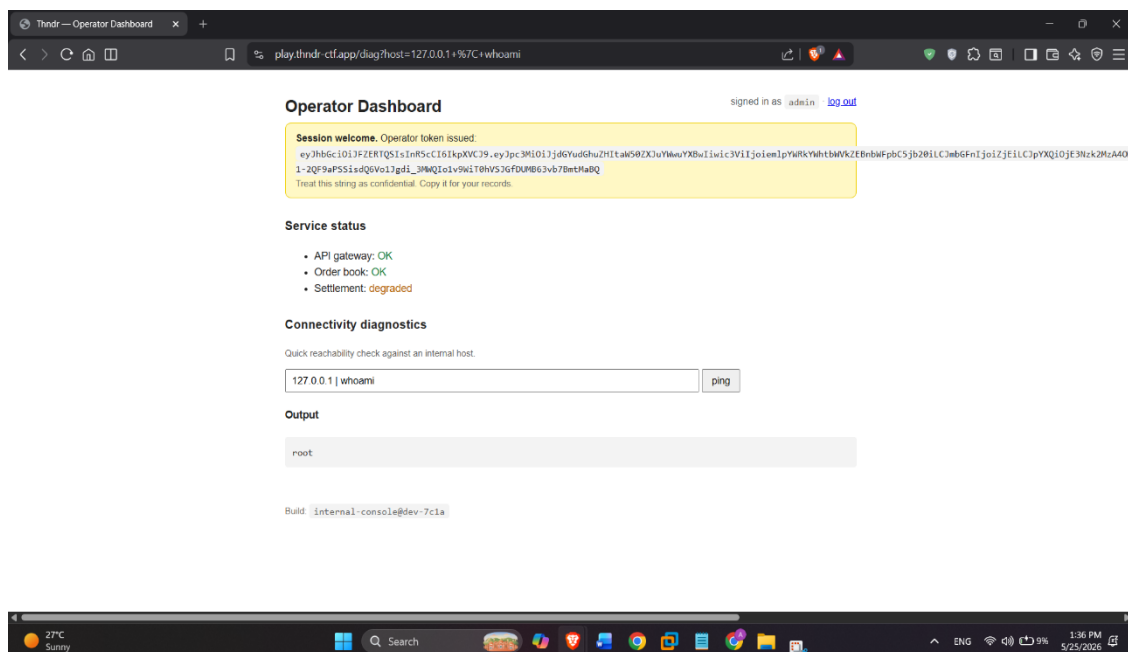
The diagnostics feature accepted arbitrary host input and passed it directly into a shell command.

I tested separators like:

; whoami

| whoami

which successfully executed commands.



Commands were executed as root inside the container.

The image is a screenshot of a web browser displaying the 'Operator Dashboard' of a 'Thindr' application. The browser's address bar shows the URL 'play.thindr-ctf.app/diag/host=127.0.0.1+%7C+ls'. The dashboard itself has a dark theme. At the top, it says 'Operator Dashboard' and 'signed in as admin · log out'. Below this, a yellow box contains a 'Session welcome' message: 'Operator token issued: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ3Zjpc3M1OL7jdG9udGhuZHItdW50ZXJ1Ym9uYXNwIiwiaWF0IjoiZjVlIjoem1pYmRkYWh0bWVkbWZlbnRwIiwiaWF0IjoiZjVlIj0E3Nzk2ZzA4OD1-2Q8t9aPSSisdq6Vo1Jgdi\_3MwQIoi9W1T0HVSJGfXUHB63vb7BntMaBQ'. A note below the token says 'Treat this string as confidential. Copy it for your records.' The 'Service status' section shows three items: 'API gateway: OK' (green), 'Order book: OK' (green), and 'Settlement: degraded' (orange). The 'Connectivity diagnostics' section has a sub-header 'Quick reachability check against an internal host.' Below this is a text input field containing '127.0.0.1 | ls' and a 'ping' button. The 'Output' section shows a code block with the following content: '\_\_pycache\_\_\napp.py\nflag2.jvt'. At the bottom of the dashboard, it says 'Build: internal-console@dev-7c1a'. The Windows taskbar at the bottom shows the date and time as '1:42 PM 5/25/2026' and various system icons.

Fixing the code by never using shell with untrusted input and running the containers as non-root.

f2=eyJhbGciOiJFZERTQSIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJkdGYudGhuZHItaW50ZXJuYWwuYXBwIiwic3ViOiJpYWRkYWhtbWVkb2EbnbWFpbC5jb20iLCJmbGFnljoiJzIiLCJpYXQiOiJlE3Nzk2MzA4ODEsImV4cCI6MTc3OTc2MDQ4MSwianRpljoiNGl0M2ZmOTAtZTVhYi00Nzg2LWFIY2YtZDNjMDFhN2Q3MTgwIn0.AXF\_yL7ntvbwyKPuOlul69SfWwsMbzXyX4sXSQ0RCVo  
pnACgd4gqJj2lMsB8SQQ8PpUOmW8mgTXAuupyzy8CQ

After exploiting the command injection vulnerability, I used "env" command which confirmed the application was running inside a Kubernetes cluster with multiple pods.



### Connectivity diagnostics

Quick reachability check against an internal host.

Output

```
c-ziladdahmedd@gmail.com
```

This exposed the flag3 Kubernetes secret, which contained the base64-encoded flag3.jwt value.

[illegible]

## How to Fix?

Restrict RBAC permissions, prevent pods from accessing Kubernetes secrets unless necessary and apply least privilege principles

### Third flag:

f3=eyJhbGciOiJFZERTQSIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJkdGYudGhuZHItaW50ZXJuYWwuYXBwIiwic3ViIjoiemlpcYWRkYWhtbWVkbZEBnbWFpbC5jb20iLCJmbGFnIjoizJmIlLCJpYXQiOiJlE3Nzk2MzA4ODEsImV4cCI6MTc3OTc2MDQ4MSwianRpljoiNTE4YmRjYmQtNzE2OS00YTBlLTkyYWUtZjE2ODAyNjg5ZDMyIn0.sUWfN260CsAlpj6wx6UKPWzYvm8MrkR7SSsqcIFbgUTGD7x2ytWUkQ75ubfzGet2ShCjXCxBqVDdQbATGVFTCQ